

SQL Injection – Authentication Bypass

Lab: PortSwigger Web Security Academy

Vulnerability: SQL Injection (SQLi)

Severity: High

Tool: Burp Suite Professional

OWASP Top 10: A03:2021 – Injection

CWE: CWE-89 – SQL Injection

Description

The application's login functionality is vulnerable to SQL Injection. User-controlled input is incorporated into the SQL query without proper parameterization.

Exploitation

Using **Burp Suite Professional**, the login request was intercepted and modified in Burp Repeater. A SQL injection payload was inserted into the username parameter to manipulate the authentication query and bypass password verification.

Impact

Successful exploitation allows an attacker to bypass authentication and gain unauthorized access to the targeted account.

Remediation

Use **prepared statements/parameterized queries** and ensure that user input is never interpreted as SQL syntax.

Result

Authentication bypass successfully demonstrated in the PortSwigger controlled lab environment.